

Akella Raghavendra Sir
Founder & Chief Mentor

[GS II: E-GOVERNANCE AND REGULATORY ACCOUNTABILITY. • GS III: CYBERSECURITY, INFORMATION TECHNOLOGY AND PROTECTION OF DIGITAL INFRASTRUCTURE. • GS IV: CORPORATE GOVERNANCE AND PROFESSIONAL ACCOUNTABILITY.]

Publication Date: 27/10/2026

eMudhra Certificate Issue: Larger Questions over Digital Trust



The eMudhra certificate issue raises larger questions about the security and accountability of institutions that underpin digital trust. The article explores why India needs reliable certification systems, stronger technical audits and transparent disclosures to protect its digital economy.

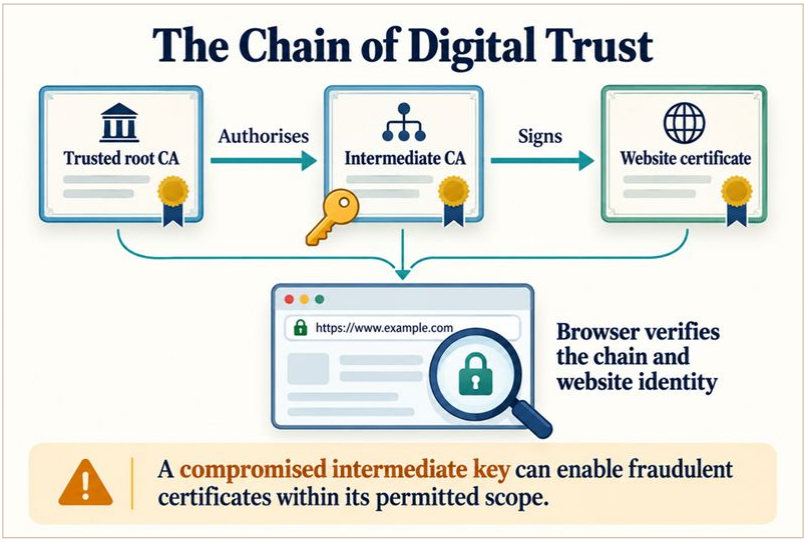
eMudhra Certificate Issue: Larger Questions over Digital Trust

UPSC syllabus linkage: GS II: E-governance and regulatory accountability. **GS III:** Cybersecurity, information technology and protection of digital infrastructure. **GS IV:** Corporate governance and professional accountability.

A researcher reportedly demonstrated possession of **eight private keys associated with eMudhra's intermediate certificates** and alerted Apple, Google, Microsoft and Mozilla. Chrome and Firefox subsequently blocked the affected certificates.

MeitY stated that the impact was limited and that **Aadhaar eSign and domestic digital signature services remained unaffected**.

The larger issue, however, concerns **the reliability of certificate authorities, the effectiveness of security audits and the protection of systems beyond web browsers**.



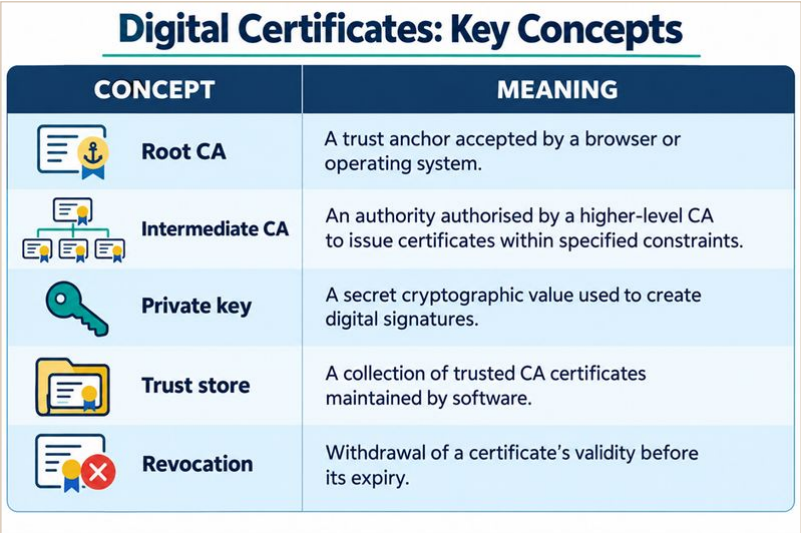
The Basics: How Does Internet Trust Work?

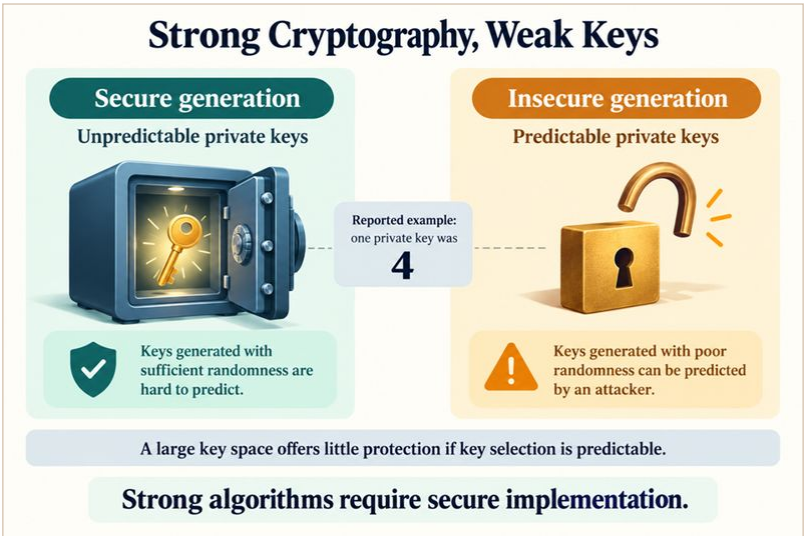
When users open a bank's website, their browser must verify that it is communicating with the genuine website.

A **digital certificate** links a website's identity to its public cryptographic key. A **Certificate Authority (CA)** digitally signs this certificate, enabling software to verify its authenticity.

Verification follows a **chain of trust**:

Website certificate !' Intermediate CA certificate !' Trusted root certificate





Why does a CA's private key matter? If an attacker obtains an intermediate CA's private key, they may create fraudulent certificates within that authority's permitted scope. These could enable **website impersonation and interception of communications**, subject to other security checks.

What Went Wrong?

Weak Key Generation

The affected keys were expected to be securely generated values within a **384-bit elliptic-curve cryptographic system**. Researchers reportedly found extremely small values, including **one private key equal to 4**.

The concern was therefore **the predictability of the keys**, which made them easy to recover despite the strength of the underlying cryptographic system.

The Company's Explanation

According to eMudhra, the keys originated during a formal **key-generation ceremony in April 2025**, using certified hardware.

The company suggested that a flaw during **key wrapping and unwrapping**, used to protect keys during transfer, produced a weak duplicate set associated with the affected certificates. The precise cause remained unresolved.

Failure of Detection

The company reportedly stated that the certificates had **passed two independent audits and remained trusted for approximately 18 months**.

This raises questions about whether audits adequately examined **technical outcomes alongside procedural compliance**. It does not, by itself, establish that all cybersecurity audits are limited to checking procedures.



How Was the Immediate Risk Contained?

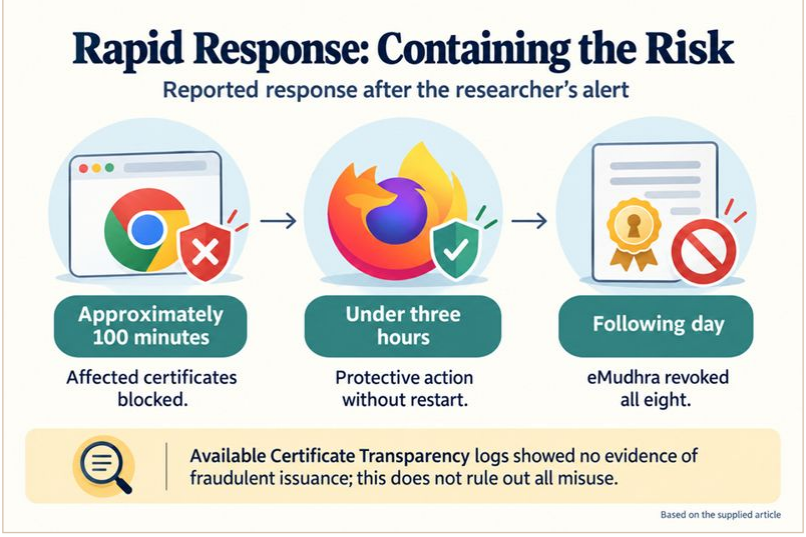
Browser providers reportedly responded rapidly:

- **Chrome:** Blocked the affected certificates within approximately **100 minutes**.
- **Firefox:** Acted in **under three hours**, without requiring an update or restart.
- **eMudhra:** Revoked all eight affected certificates the following day.

Available **Certificate Transparency logs reportedly showed no evidence of fraudulent certificate issuance**.

These logs support public scrutiny of certificate issuance. However, **the absence of suspicious entries does not conclusively rule out every form of misuse**, because logs do not capture all network activity or attacks.

Authorities also stated that **domestic eSign services operated on separate systems and remained unaffected**.



The Larger Risk: Systems Beyond Browsers

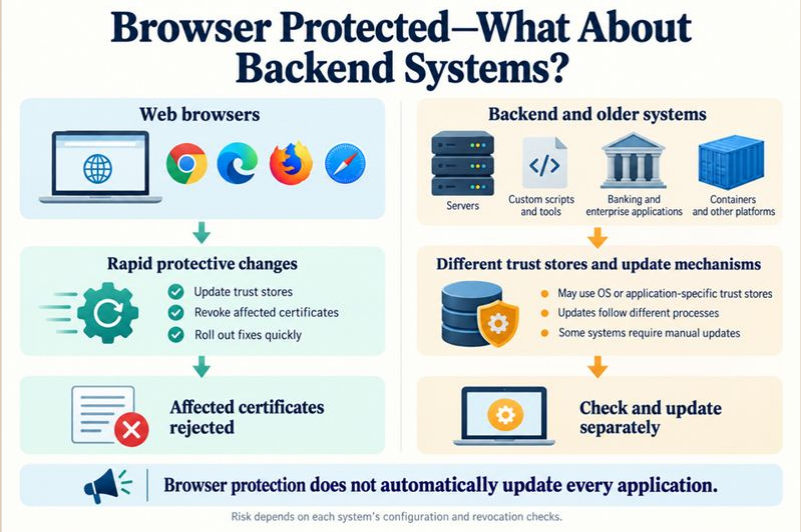
A browser's rapid response does not automatically protect every application using digital certificates.

Backend banking applications, automated scripts, server tools, containerised software and older mobile components may rely on different trust stores and update mechanisms.

Some systems may:

- Use outdated certificate bundles.
- Lack automatic security updates.
- Omit revocation checks by default.
- Apply revocation checks inconsistently.

Consequently, an affected certificate chain may remain trusted until the relevant software, configuration or trust store is updated.

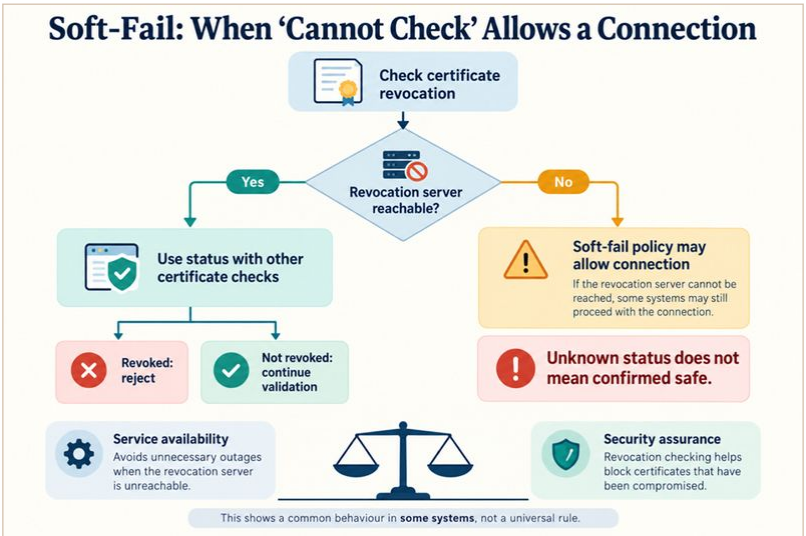


What Is "Soft-Fail" Revocation Checking?

A system may attempt to check whether a certificate has been revoked but fail to reach the relevant server.

Under **soft-fail behaviour**, it may allow the connection despite being unable to confirm the certificate's status.

This balances service availability against security, but can leave systems exposed when revocation information is unavailable.



Why Is This Important for India?

Security of Digital Services

Taxation, identity verification, banking and e-governance rely on cryptographic trust. Weaknesses in supporting infrastructure can undermine secure transactions and public confidence.

Accountability of Trust Providers

Certificate authorities perform a critical function within the digital economy. Their responsibilities require **secure key management, independent scrutiny and transparent incident disclosure**.

Limits of Certification

Certified hardware and completed audits provide assurance, but their effectiveness depends on **what is tested, how it is tested and whether weaknesses are corrected**.

Uneven Cybersecurity Preparedness

Large browsers can distribute protective changes quickly. Organisations maintaining older or customised software may respond more slowly, creating uneven protection across the digital ecosystem.



The eMudhra episode highlights how **weak implementation and inadequate detection can undermine otherwise strong cryptography**. Protecting India's digital ecosystem requires effective audits, secure key management and timely remediation across browsers, applications and backend systems.

Mains practice question: *"Procedural compliance alone cannot ensure cybersecurity." Discuss with reference to certificate authorities and digital trust infrastructure.*

Also read article on emudhra - **eMudhra Certificate Controversy: Cybersecurity and India's Digital Trust**